PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Panorama de la cybermenace 2025

03-10 ANSSI - Panorama de la cybermenace 2025 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'extorsion de fonds via les rançongiciels cible prioritairement les PME, la santé et l'éducation.
2. L'espionnage stratégique russe et chinois vise les secteurs gouvernementaux et diplomatiques pour le renseignement.
3. La compromission des équipements de bordure comme les pare-feu ou VPN mobilise fortement les équipes de réponse.

Motivations des attaquants

Notion	À retenir
L'extorsion de fonds	Rançongiciels (légère baisse en **2025**) ciblant **PME**, **santé** et **éducation**. Certains groupes pratiquent l'**exfiltration sans chiffrement** pour monétiser ou revendre des accès.
L'espionnage stratégique	Modes opératoires **russes** et **chinois** ciblant les secteurs **gouvernementaux** et **diplomatiques** pour collecter du renseignement via des réseaux ou infrastructures critiques.
La déstabilisation et le sabotage	Codes destructeurs sur les **infrastructures énergétiques** (**Ukraine** ; **Sandworm**, russe, contre le réseau électrique **polonais**). Groupes **hacktivistes** utilisant **DDoS** et attaques sur **petites installations industrielles** peu sécurisées pour nuire à la réputation.

Évolution des capacités des attaquants

Notion	À retenir
Services et IA	Détournement d'**outils d'administration à distance** et de **services de stockage** pour dissimuler le trafic ; l'**IA** génère des sites crédibles ou optimise la **reconnaissance**.
Ingénierie sociale	Maîtrise de la **fatigue d'authentification multifactorielle**, de l'**hameçonnage vocal** ou l'incitation à exécuter des **commandes malveillantes** perçues comme légitimes.
Suivi des capacités	L'**imputation** est difficile via l'usage d'**outils publics** partagés ; les **fuites de données internes** de groupes majeurs révèlent leur organisation et outils.

Opportunités d'accès et vecteurs de menace

Notion	À retenir
Contextes spécifiques	Faiblesses des **SI bureautiques** (manque d'audits), **cadres légaux étrangers** (logiciels espions) et **événements politiques/diplomatiques** (pics d'attaques).
Vulnérabilités techniques	Cibles : **équipements de bordure** (pare-feu, VPN), ciblés **dès la publication des failles**, **virtualisation**, **serveurs de messagerie** et **terminaux mobiles** (vulnérabilités sans clic).
Chaîne d'approvisionnement	Compromission de **prestataire informatique** (déplacement latéral) ou d'**environnements dans le nuage** (paralysie de dizaines d'organisations).

Pièges et confusions

⚠ Croire que les réactions précipitées lors d'un incident sont bénéfiques (elles peuvent engendrer des dégâts supérieurs à l'attaque).
⚠ Penser que les frontières entre acteurs étatiques et groupes cybercriminels sont clairement définies.
⚠ Confondre l'usage d'outils publics partagés avec une facilité d'imputation des attaques.
⚠ Ignorer que les attaques sur terminaux mobiles peuvent être des vulnérabilités sans clic.

Sigles et définitions

Rançongiciel	code malveillant déployé pour bloquer l'accès aux données en échange d'une rançon
Double extorsion	technique consistant à chiffrer les données puis à menacer de les divulguer
Infostealer	code malveillant conçu pour collecter des informations sur le poste de travail de la victime
Courtier en accès initial	attaquant qui s'introduit dans un système pour revendre cet accès
Hacktiviste	acteur malveillant agissant pour des motivations politiques ou idéologiques
Tunneling	méthode permettant de transporter des données sur un réseau via des protocoles non pris en charge
Lolbins	binaires légitimes d'un système d'exploitation détournés de manière furtive

Auto-test

1. Quels secteurs sont principalement ciblés par les rançongiciels ?
2. Quel est l'objectif des modes opératoires russes et chinois ?
3. Quels types d'équipements de bordure sont des cibles de vulnérabilités techniques ?
4. Que peut générer l'IA dans le cadre des capacités des attaquants ?
5. Quelle conséquence peut avoir la compromission d'un environnement dans le nuage ?

Réponses : **1.** PME, santé et éducation · **2.** Collecter du renseignement via des réseaux ou infrastructures critiques · **3.** Pare-feu, VPN · **4.** Des sites crédibles ou l'optimisation de la reconnaissance · **5.** La paralysie de dizaines d'organisations

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.